LAB-01 — Protección y privacidad de datos

Materia: Gestión de Seguridad y Desempeño de Bases de Datos
Unidad: II — Seguridad, privacidad y control de acceso
Actividad: Actividad 3 — Seudonimización y separación de funciones
Estudiante: Carlos Romero
Grupo: 4

Actividad 3 — Seudonimización y separación de funciones

Objetivo

El objetivo de esta actividad es permitir que el área de analítica pueda trabajar con información de los clientes sin acceder directamente a su identidad.

Para ello se implementó un mecanismo de seudonimización mediante tokens UUID. Cada cliente fue asociado con un identificador sustituto, mientras que la información necesaria para relacionar nuevamente dicho token con el registro original se almacenó de manera separada.

También se aplicó el principio de separación de funciones, evitando que el rol destinado al análisis pueda consultar simultáneamente los datos seudonimizados, el mapa de correspondencia y la información original de los clientes.

Evidencia 1 — Verificación de los esquemas

Para separar la información de acuerdo con su nivel de sensibilidad se utilizaron los esquemas pii y analitica.

La existencia de ambos esquemas se comprobó mediante:

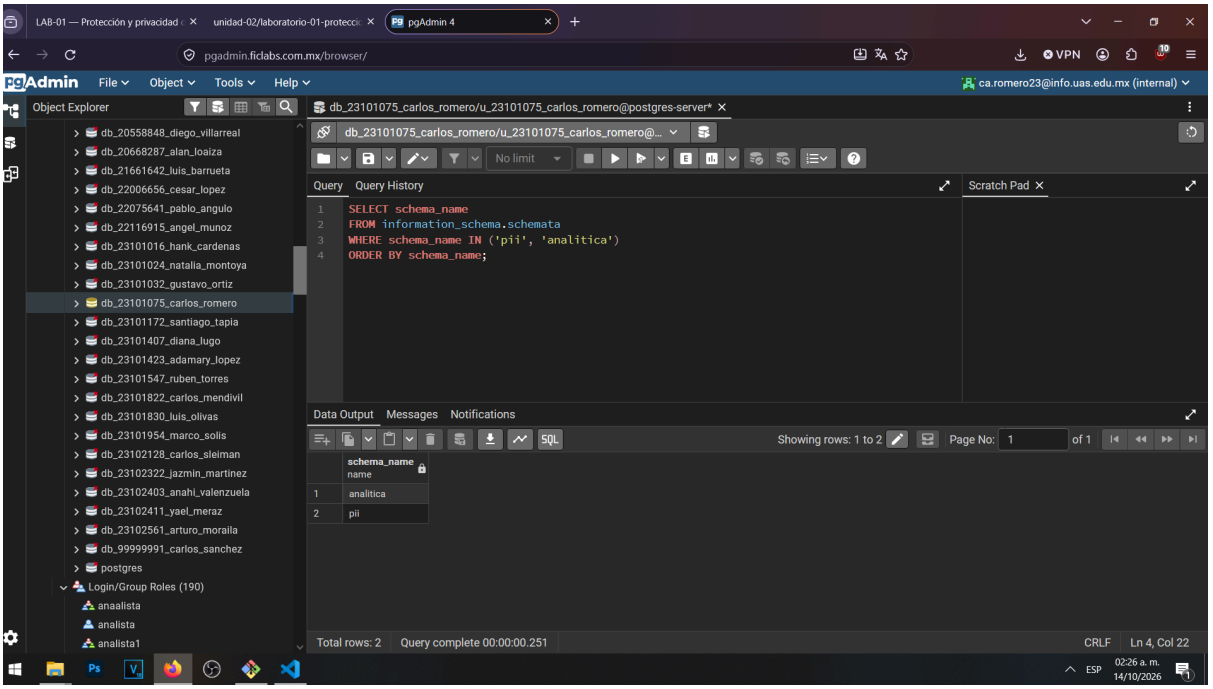
SELECT schema_name

FROM information_schema.schemata

WHERE schema_name IN ('pii', 'analitica')

ORDER BY schema_name;

Captura de evidencia



Resultado

La consulta confirmó la existencia de los esquemas pii y analitica.

El esquema pii se utiliza para almacenar información de mayor sensibilidad, específicamente el mapa que permite relacionar los tokens con los identificadores originales.

El esquema analitica contiene la información destinada al análisis, separada de los identificadores directos.

Evidencia 2 — Verificación de registros en las estructuras

Se comprobó que tanto la tabla de correspondencia como el conjunto analítico contienen los cinco registros utilizados durante el laboratorio.

La consulta utilizada fue:

```
SELECT
    'pii.mapa_cliente' AS tabla,
    COUNT(*) AS registros
FROM pii.mapa_cliente
```

UNION ALL

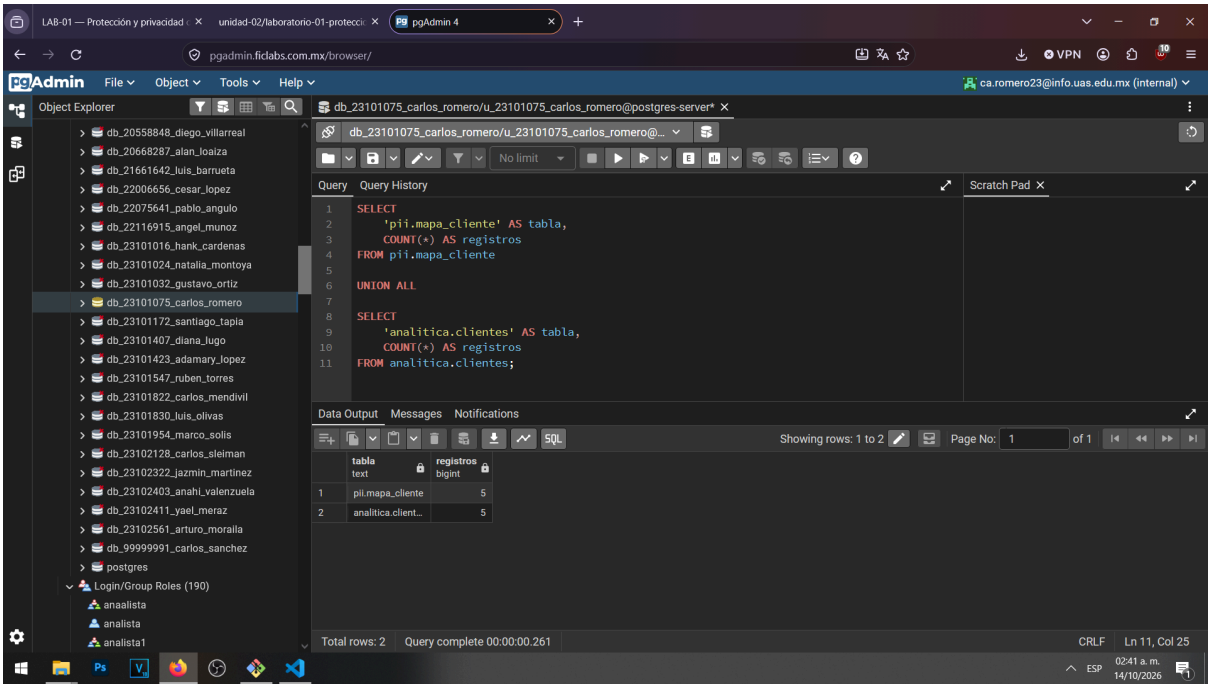
SELECT

'analitica.clientes' AS tabla,

COUNT(*) AS registros

FROM analitica.clientes;

Captura de evidencia



Resultado

La consulta confirmó que:

pii.mapa_cliente → 5 registros

analitica.clientes → 5 registros

Esto demuestra que existe una correspondencia para los cinco clientes y que los cinco registros también se encuentran disponibles en el conjunto preparado para analítica.

Evidencia 3 — Generación de tokens UUID

Se generó un identificador sustituto de tipo UUID para cada uno de los clientes.

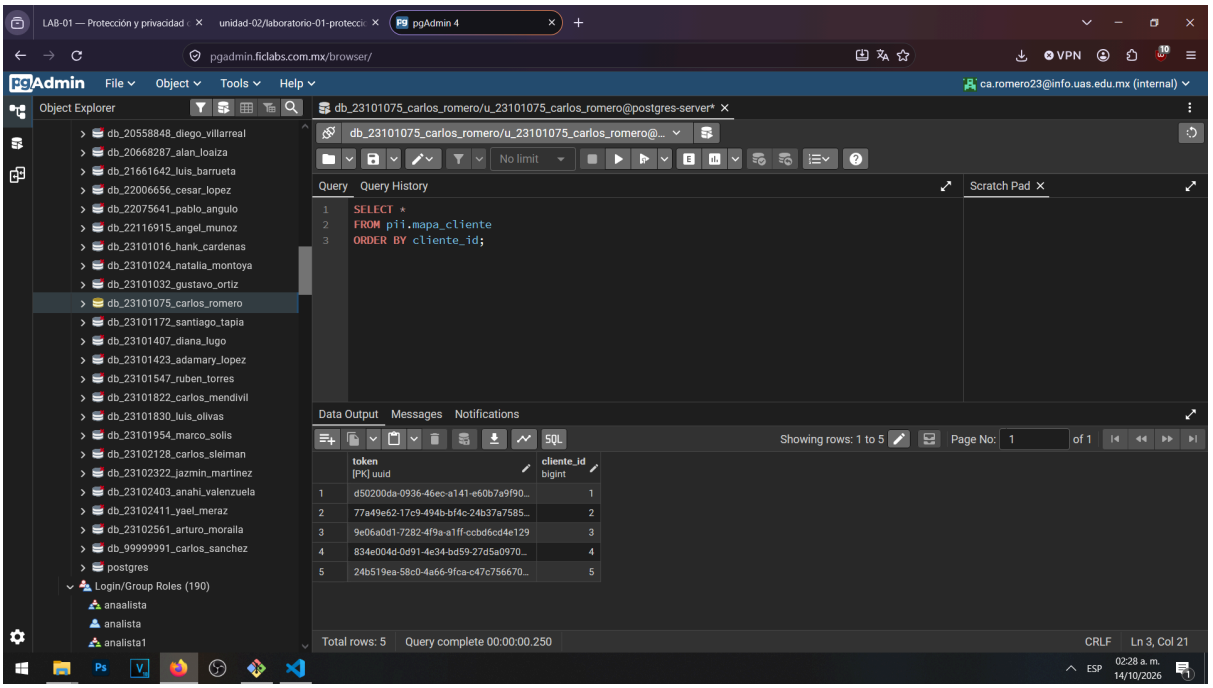
La tabla de correspondencia puede consultarse mediante:

SELECT *

FROM pii.mapa_cliente

ORDER BY cliente_id;

Captura de evidencia



Resultado

La tabla pii.mapa_cliente contiene un token UUID diferente para cada cliente.

Cada token se encuentra relacionado con un cliente_id, estableciendo una correspondencia similar a:

token → cliente_id

El token funciona como un identificador sustituto y evita que el área de analítica necesite utilizar directamente el identificador original del cliente.

La tabla de correspondencia requiere un nivel de protección mayor debido a que permite recuperar la relación entre el token y el registro original.

Evidencia 4 — Conjunto de datos seudonimizado

Se creó el conjunto:

analitica.clientes

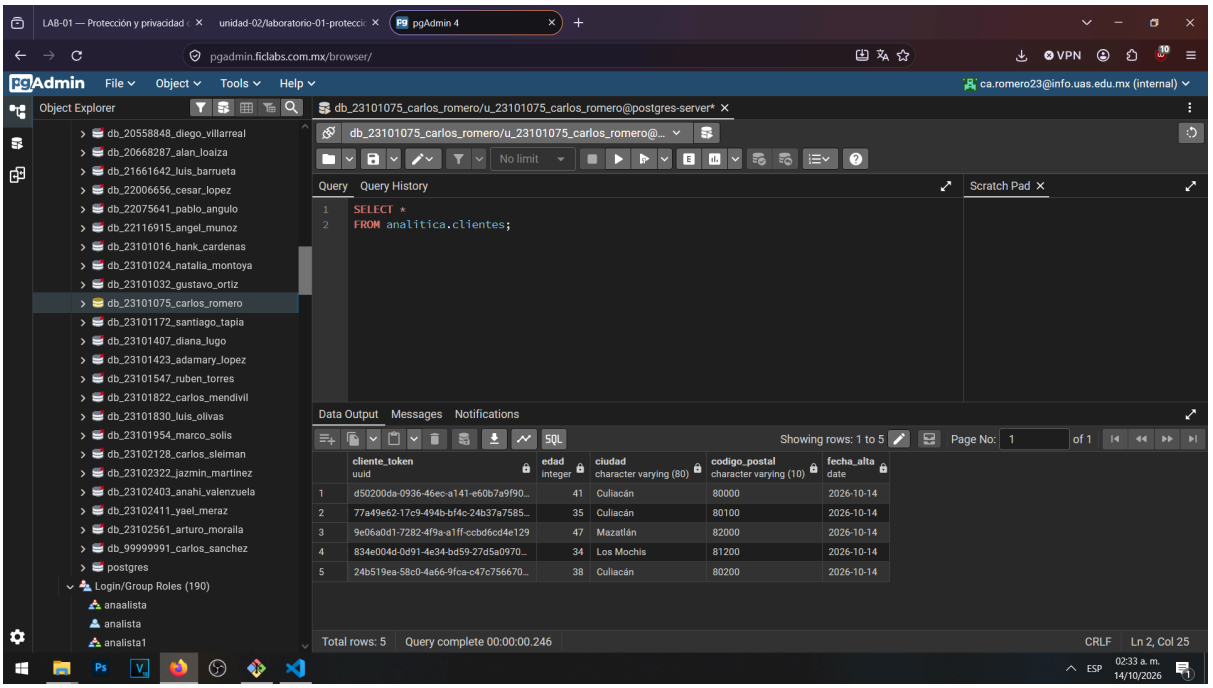
para proporcionar al área de análisis únicamente los atributos necesarios.

La consulta utilizada fue:

SELECT *

FROM analitica.clientes;

Captura de evidencia



Resultado

El conjunto analítico contiene cinco registros y utiliza el campo cliente_token en lugar del identificador original.

Además, contiene información como:

edad

ciudad

codigo_postal

fecha_alta

No se incluyen identificadores directos como:

nombre

correo

telefono

rfc

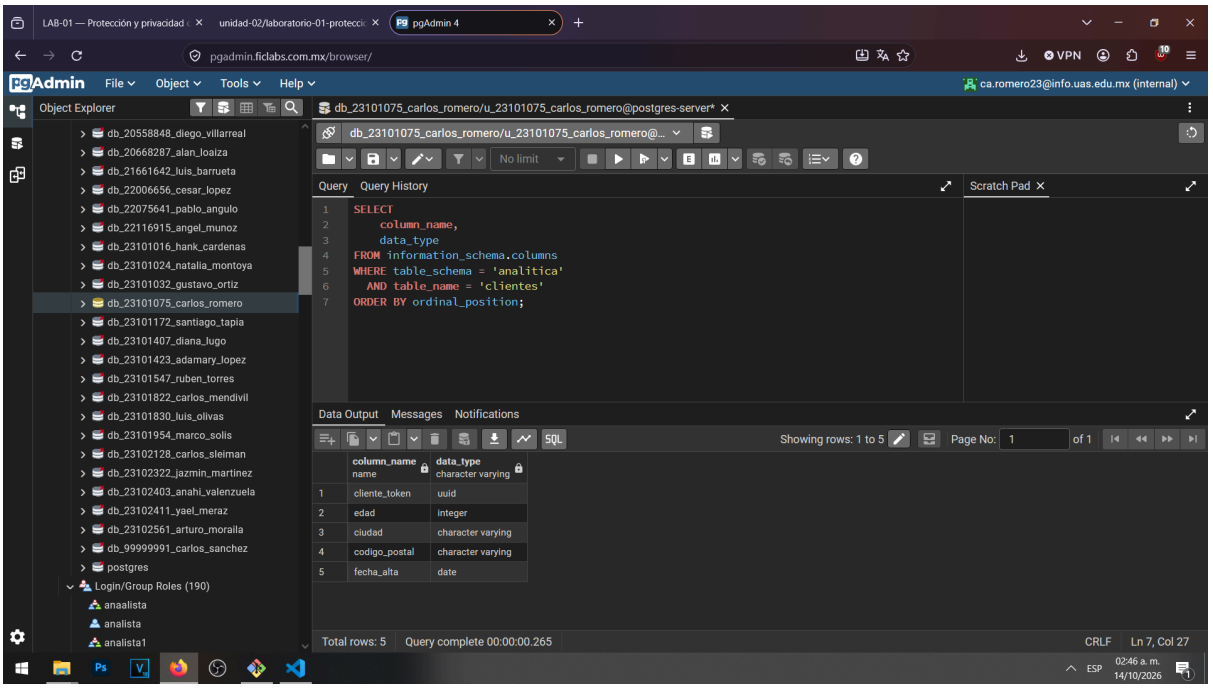
De esta manera, el área de analítica puede utilizar información útil para estudiar tendencias sin conocer directamente la identidad de los clientes.

Evidencia 5 — Verificación de las columnas disponibles

Para demostrar que el conjunto analítico no contiene los identificadores directos se consultó su estructura mediante:

```
SELECT
    column_name,
    data_type
FROM information_schema.columns
WHERE table_schema = 'analitica'
  AND table_name = 'clientes'
ORDER BY ordinal_position;
```

Captura de evidencia



Resultado

La consulta confirmó que analitica.clientes contiene únicamente las siguientes columnas:

cliente_token

edad

ciudad

codigo_postal

fecha_alta

No aparecen nombre, correo, telefono ni rfc.

Esta separación reduce la exposición de los identificadores directos de los clientes.

Evidencia 6 — Verificación de privilegios del analista

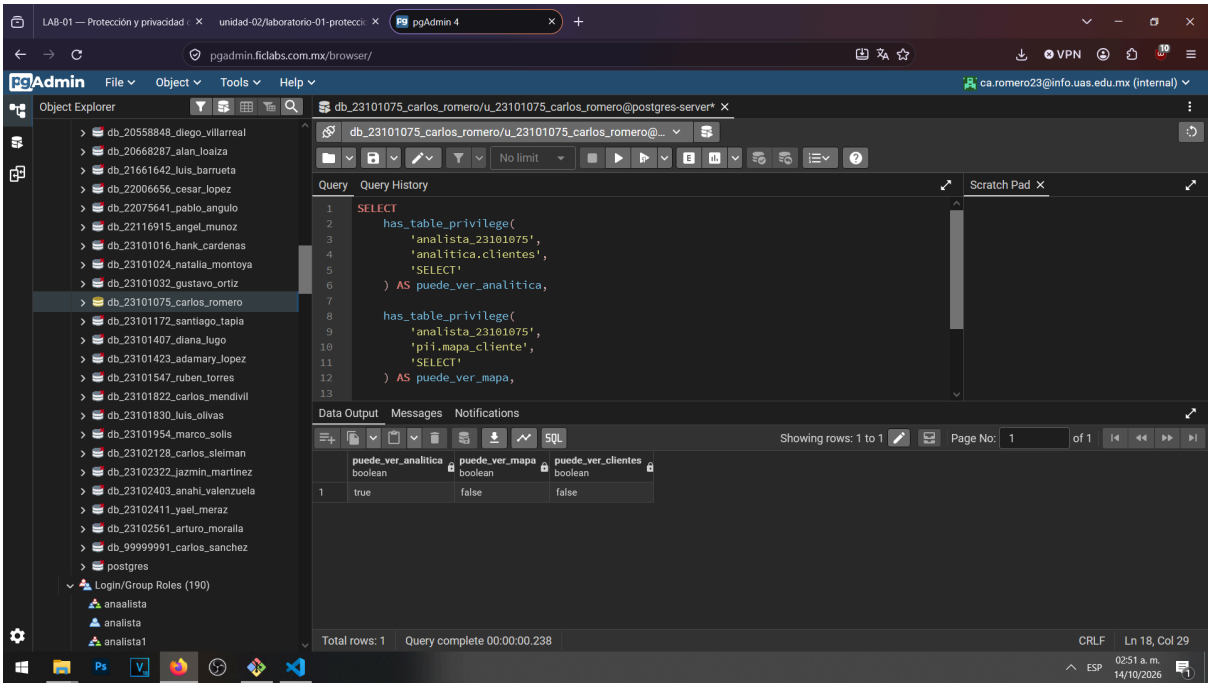
Debido a que el servidor PostgreSQL de FICLabs es compartido, se utilizó un nombre de rol único:

analista_23101075

Al rol se le permitió consultar únicamente analitica.clientes.

Los privilegios se comprobaron mediante has_table_privilege.

Captura de evidencia



Resultado

La comprobación produjo los siguientes valores:

puede_ver_analitica = true

puede_ver_mapa   = false

puede_ver_clientes = false

Esto demuestra que el rol analista_23101075 puede consultar el conjunto destinado al análisis, pero no puede acceder al mapa de correspondencia ni a los datos originales.

De esta manera se aplican los principios de mínimo privilegio y separación de funciones.

Evidencia 7 — Verificación del rol activo

Para realizar una prueba real de los permisos se otorgó al usuario de la práctica la posibilidad de asumir temporalmente el rol:

GRANT analista_23101075

TO u_23101075_carlos_romero;

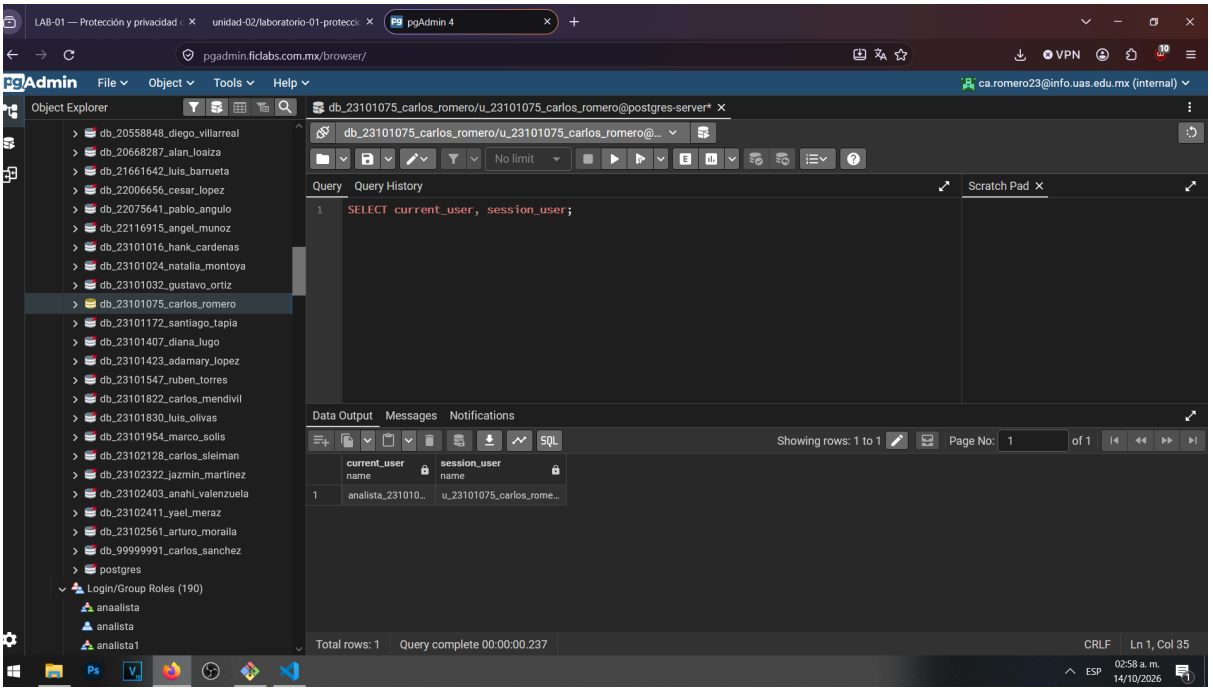
Después se utilizó:

SET ROLE analista_23101075;

y se verificó mediante:

SELECT current_user, session_user;

Captura de evidencia



Resultado

La consulta demuestra que current_user corresponde a:

analista_23101075

mientras que session_user continúa siendo el usuario utilizado originalmente para iniciar sesión en FICLabs.

Esto confirma que las siguientes pruebas fueron ejecutadas realmente utilizando los privilegios asignados al rol de analista.

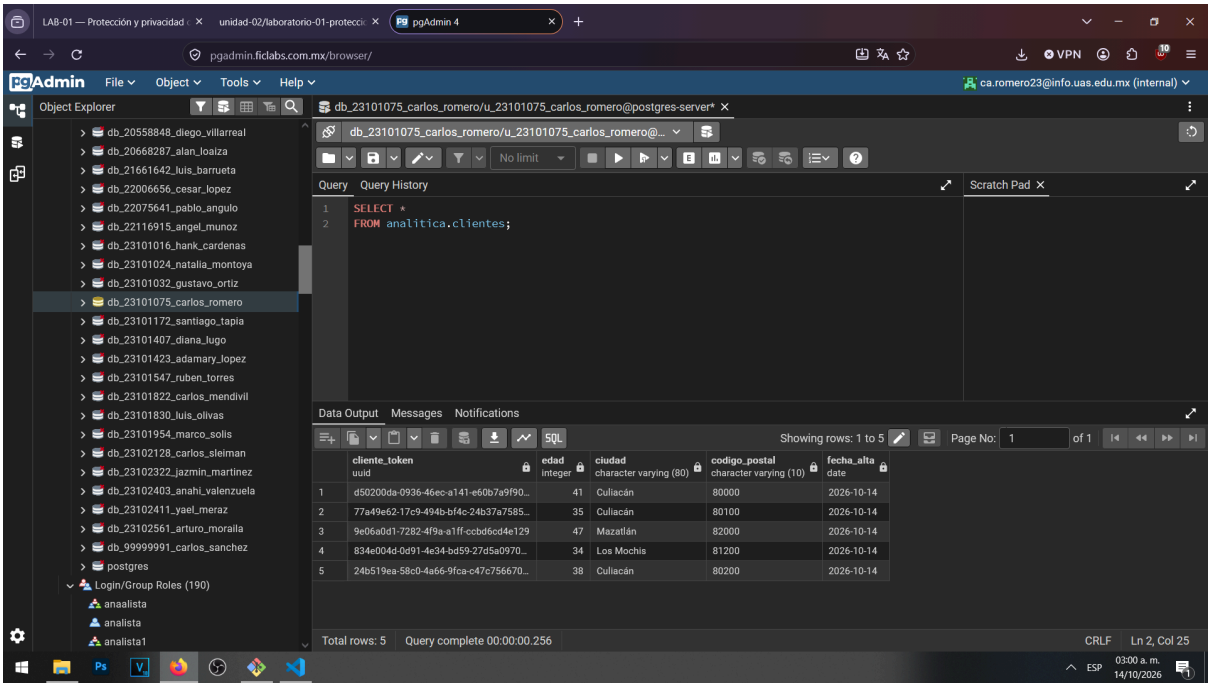
Evidencia 8 — Acceso permitido al conjunto analítico

Con analista_23101075 activo se ejecutó:

SELECT *

FROM analitica.clientes;

Captura de evidencia



Resultado

La consulta fue ejecutada correctamente y mostró los cinco registros del conjunto analítico.

El analista puede consultar los tokens, edad, ciudad, código postal y fecha de alta, ya que esta información es necesaria para realizar sus funciones.

Sin embargo, no recibe directamente los identificadores principales del cliente.

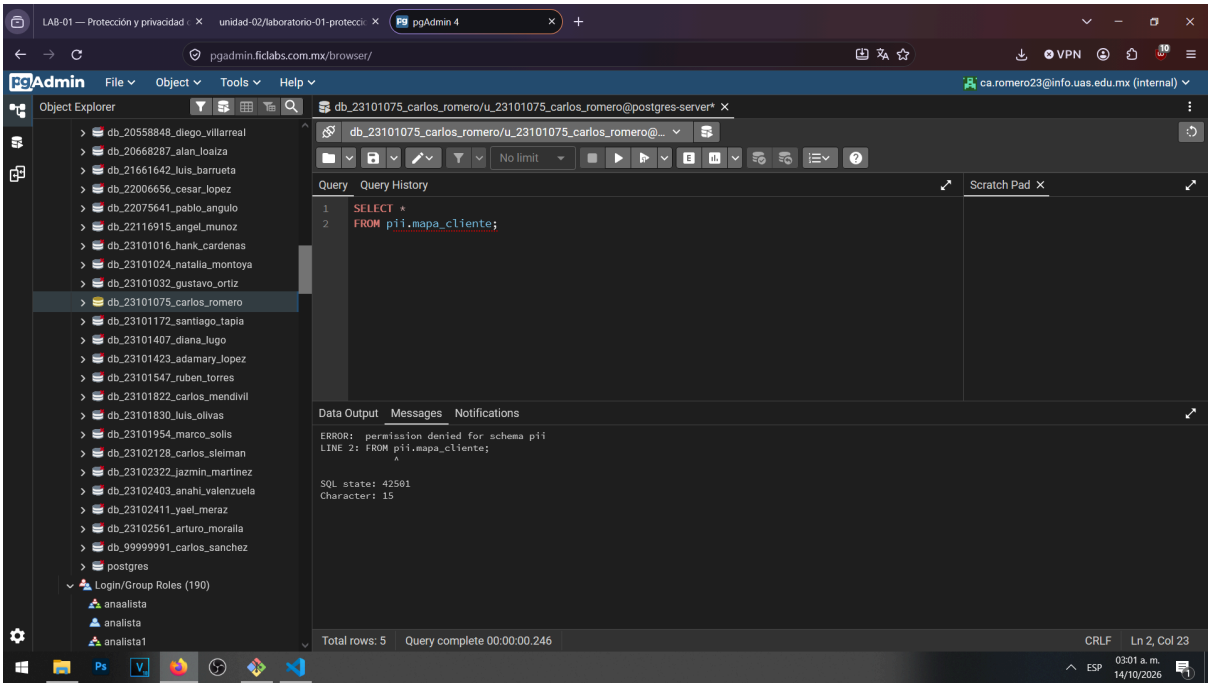
Evidencia 9 — Acceso rechazado al mapa de correspondencia

Con el rol analista_23101075 todavía activo se intentó ejecutar:

SELECT *

FROM pii.mapa_cliente;

Captura de evidencia



Resultado

PostgreSQL rechazó la consulta mostrando un error de permisos sobre el esquema pii.

Esto demuestra que el analista no puede acceder a la tabla que relaciona los tokens con los identificadores originales.

La restricción es fundamental porque, si el analista pudiera consultar el mapa, podría reducir considerablemente la protección conseguida mediante la seudonimización.

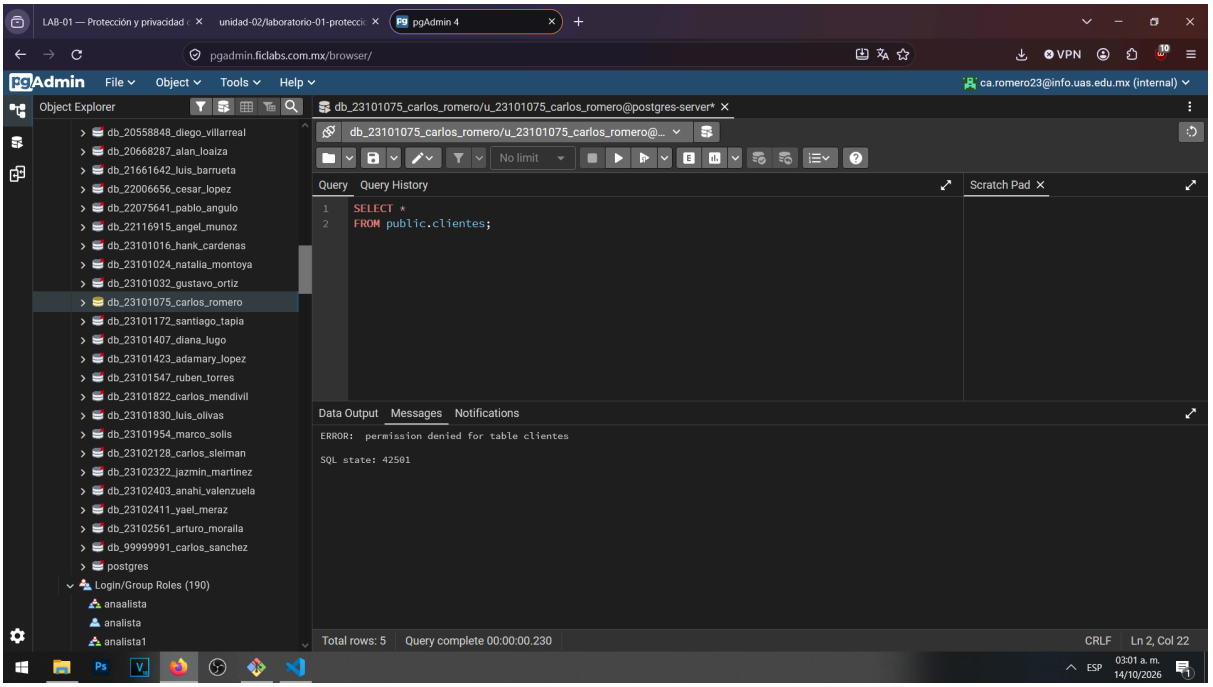
Evidencia 10 — Acceso rechazado a los datos originales

Finalmente, con el rol analista_23101075 activo, se intentó consultar directamente:

SELECT *

FROM public.clientes;

Captura de evidencia



Resultado

PostgreSQL rechazó el acceso con un mensaje equivalente a:

ERROR: permission denied for table clientes

SQL state: 42501

Esto confirma que el rol analista tampoco puede consultar directamente la tabla original que contiene nombres, correos electrónicos, teléfonos, RFC y demás información de los clientes.